

CTI 리포트 – 발코딩이 만든 쌍둥이 사건

“커밋 한 줄이 만든 침해” — Taiko 브릿지 해킹과 티빙, 데자뷔

분류	Cyber Threat Intelligence / Secret Management Failure
작성일	2026-06-28
TLP	CLEAR (공개 가능)
대상 사건	① Taiko 브릿지 해킹 (2026-06-22) · ② TVING 개인정보 유출 (2026-06)
핵심 키워드	Hardcoded Secret · Git History · Pre-commit Hygiene · SGX/MrSigner · AWS Access Key

코딩을 못하는 보안 전문가도 읽기 쉽도록 되도록 쉬운 단어로 작성하였으며, 하지만 git의 특성상 커밋 후 푸시가 되어 프라이빗 키가 유출되면 키를 폐기해야 한다는 정도의 이해도는 있어야 한다.

목차

1. 핵심 요약 (Executive Summary).....	2
2. 사건 ① — Taiko 브릿지 해킹 (2026-06-22).....	2
2.1 개요.....	2
2.2 공격 분석.....	3
2.3 사후 대응.....	4
3. 사건 ② — TVING(티빙) 개인정보 유출 (2026-06).....	4
3.1 개요.....	4
3.2 공격 분석.....	5
3.3 대응 및 논란.....	5
4. 비교 분석 — 다른 사건, 같은 실패.....	5
4.1 공통점 — 신뢰의 근(root of trust)이 평문으로 새어 나갔다.....	6
4.2 차이점 — 결과를 가른 것은 ‘탐지·대응 속도’.....	6
5. 왜 ‘프리커밋(Pre-commit) 단계’가 핵심인가.....	7
6. 권고사항 (Defensive Recommendations).....	7

7. 결론	8
부록 — 동일 패턴의 선례	9
출처	9

1. 핵심 요약 (Executive Summary)

2026년 6월, 성격이 전혀 다른 두 사건이 거의 같은 시기에 발생했다. 하나는 영지식(ZK) 롤업 기반 이더리움 L2 **Taiko**의 브릿지에서 약 **170만 달러(원화 약 24억 원 상당)**가 인출된 Web3 해킹이고, 다른 하나는 국내 대형 OTT **티빙(TVING)**에서 약 **1,900만 명** 규모의 개인정보가 유출된 사고다.

기술 스택도, 피해 형태도, 산업도 다르지만 **근본 원인은 동일하다.**

“코드 저장소(GitHub)에 들어가서는 안 될 비밀키·자격증명이 커밋되었고, 공격자는 그것을 그대로 주워 썼다.”

즉 두 사건 모두 정교한 익스플로잇 체인이나 제로데이가 아니라, **커밋(commit) 단계에서 걸러졌어야 할 시크릿 관리 실패**가 출발점이었다. 가장 정교한 신뢰 모델(Taiko의 SGX 하드웨어 신뢰, 티빙의 ISMS 인증·DB 암호화)도 ‘단 하나의 노출된 키’ 앞에서 통째로 무력화됐다는 점에서 인간은 참 쉬운 보안 규칙을 어기는 존재라는 점이다.

2. 사건 ① — Taiko 브릿지 해킹 (2026-06-22)

2.1 개요

- **대상:** 이더리움 L2 Taiko (Type-1 ZK-EVM 롤업, 2024 년 5 월 메인넷 가동)

- **피해:** 브릿지 및 ERC20Vault 컨트랙트에서 약 \$1.7M 인출 (ETH 및 ERC-20 자산 중심)
- **탐지·대응:** Blockaid 실시간 탐지, BlockSec(Phalcon)·PeckShield·Quill Audits 원인 분석. 사고 발생 수 시간 내 동결
- **시장 영향:** TAIKO 토큰 약 10~20% 하락, 공격자는 약 200 만 TAIKO(약 \$170K)를 MEXC 로 이동

2.2 공격 분석

뭔 말인지 이해하기 쉽지 않다는 말에 따라 되도록 쉽게 작성하도록 했다. Taiko는 단일 시퀀서를 두지 않고 다중 증명(multi-prover) 구조를 채택했다. 증명 생성 스택 **Raiko**는 Intel SGX 어테스테이션과 ZK 백엔드(SP1, RISC0)를 결합해, 서로 독립적인 증명 시스템을 동시에 무너뜨려야만 위조가 가능하도록 설계되었다. 그러나 이 다중 구조는 **단 하나의 운영 실수로 해킹에 속하지 않은 쉬운 인증이 우회되었다.**

1. **키 노출:** SGX 엔클레이브 서명용 RSA-3072 개인키가 enclave-key.pem 파일로 공개 저장소 taikoxyz/raiko 에 커밋되어 누구나 내려받을 수 있는 상태였다. 본래 하드웨어(엔클레이브) 밖으로 절대 나가서는 안 되는 값이다.
2. **악성 프로버 등록:** L1 컨트랙트는 저장된 MrSigner 값과 일치하는 엔클레이브를 신뢰하도록 설계돼 있었다. 공격자는 탈취한 키로 SgxVerifier.registerInstance 를 호출해 자신이 통제하는 프로버를 '정상'으로 등록했다.
3. **위조 증명 생성:** 신뢰받는 프로버가 가짜 L2 상태 어테스테이션과 출금 증명에 서명했다.
4. **자산 인출:** Taiko L2 의 입금(MessageSent 이벤트) 없이 이더리움 L1 에서 출금 요청을 제출했다. 검증을 통과한 증명을 컨트랙트가 거부할 방법이 없어 자산이 그대로 빠져나갔다.

개발자 마스터 개인 키를 Github에 올렸고 그걸 다운 받은 공격자가 L2에 있는 코인 자산 출금에 서명했다.

하드웨어 기반 신뢰 모델 자체는 '정상 작동'했다. 다만 잘못된 운영자(공격자)를 신뢰했을 뿐이다.

2017 년 블록체인 업계에서 메인넷과 L2 라고 주장하는 상당한 프로젝트는 관리가 부실했다. 대부분 민스크에서 만들어지거나 광저우에서 클론이 만들어졌기 때문에 pem 이 외주자가 보관하는 경우도 많았다.

비트코인 계열에서 포크한 프로젝트 5 개, ERC20 계열의 월렛의 지갑 8 종의 유저 PIN 은 난독화가 거의 안되어 있는 경우도 많았고 5.x 대 PHP 버전을 사용하는 phpadmin 을 관리툴로 확장해서 쓰는 중국계 거래소는 지금도 있다.

Geth 를 포크 뜨고 롤업 부분을 Rust 로 바꾼 것이 무슨 기술적 성취와 포인트를 가지고 있는지에 대해서 잘 이해가 되지 않는다.

2.3 사후 대응

Taiko 팀은 Security Council 멀티시그를 가동해 브릿지·ERC20Vault를 일시 정지하고 블록 생성을 중단했으며, 모든 사용자에게 **즉시 브릿지에서 자금을 인출**하도록 긴급 공지했다. 동시에 CEX에 TAIKO 입금 중단을 요청했다. 피해가 비교적 작게 끝난 결정적 이유는 수 시간 내 탐지, 동결이었다.

3. 사건 ② — TVING(티빙) 개인정보 유출 (2026-06)

3.1 개요

- **대상:** 국내 대형 OTT 티빙 (MAU 770 만+)
- **피해:** 약 1,953 만 명 규모. 아이디·이름·생년월일·성별·전화번호·이메일과 함께 CI/DI 유출(전화번호·이메일·환불계좌·비밀번호는 암호화 상태). CI 유출로 2·3 차 피싱 우려가 핵심 쟁점

- **연쇄:** CJ ONE 통합 로그인 연동 계정으로 위험 확산, 동시기 데이원컴퍼니(패스트캠퍼스)에서도 GitHub 마스터 계정 키 탈취 사고 발생

3.2 공격 분석

KISA 침해사고 신고서 기반 보도를 종합하면 공격 경로는 다음과 같다.

1. **키 노출:** 개발 편의를 위해 AWS 액세스 키를 소스코드에 하드코딩했고, 이 코드가 GitHub 에 올라가 자격증명이 노출됐다.
2. **DB 직접 접근:** 공격자는 그 키로 클라우드 자원, 특히 DB 서버에 직접 접속했다.
3. **쿼리 실행:** 조회·수정·삭제가 가능한 상태에서 대량 회원 정보를 추출했다. 신고서 사고 제목은 '비인가 접근에 의한 침해사고'였다.

3.3 대응 및 논란

- **탐지 지연:** 방어 체계가 공격을 탐지한 것이 아니라, 대량 추출로 DB CPU 사용률이 100%까지 치솟은 뒤에야 이상을 인지했다. 이상 징후 발생부터 인지까지 약 21 시간이 걸렸다.
- **인증의 한계:** ISMS 인증을 보유했음에도 클라우드 관리자 접속 키가 코드에 그대로 노출돼, 인증 보유와 실질 보안 수준 간 괴리가 드러났다.
- **신고 시점 논란:** 사고 인지 후 법정 신고 시한(24 시간)에 임박해 신고한 점이 '축소 의혹'으로 비판받았다.
- **사후 조치:** AWS 액세스 키 폐기, GitHub 하드코딩 자격증명 제거·교체, 공격자 IP 차단, 클라우드 접근 통제 정책 변경.

4. 비교 분석 - 다른 사건, 같은 실패

구분	Taiko 브릿지 해킹	TVING 개인정보 유출
산업	Web3 / DeFi (L2 브릿지)	OTT / 개인정보 처리
노출된 시크릿	SGX 엔클레이브 RSA-3072 서명키 (enclave-key.pem)	AWS 액세스 키 (하드코딩)

구분	Taiko 브릿지 해킹	TVING 개인정보 유출
노출 경로	공개 GitHub 저장소에 커밋	GitHub 저장소에 하드코딩·노출
무력화된 방어선	SGX 다중 프로버 하드웨어 신뢰 모델	ISMS 인증 · DB 암호화
침투 핵심 행위	악성 프로버 등록 → 위조 증명 생성	탈취 키로 DB 직접 접속 → 쿼리 실행
피해 형태	브릿지 자산 인출 (~\$1.7M)	개인정보 대량 유출 (~1,953만 명)
탐지 방식	외부 보안업체 실시간 탐지	DB 과부하(CPU 100%) 사후 인지
대응 속도	수 시간 내 동결 (피해 최소화)	약 21시간 후 인지 (피해 확대)

Taiko 브릿지는 거액의 자산이 유출될 때 슬랙이나 텔레그램에 알람을 띄우는 등의 기본적인 것도 없이 외부 보안 업체가 발견한 것이다.

Tving 은 모니터링을 담당하는 업체가 무얼 모니터링했는지가 궁금하다.

4.1 공통점 – github 에 안일하게 키를 올렸다.

두 사건의 가장 정교한 보안 장치(하드웨어 엔클레이브, 인증 체계·암호화)는 모두 ‘이 키를 가진 자는 신뢰한다’는 전제 위에 서 있었다. 그 키가 저장소에 커밋되는 순간, 신뢰 모델 전체가 공격자에게 그대로 양도됐다. 보안 통제의 강도와 무관하게, **신뢰의 근이 되는 시크릿이 노출되면 모든 상위 통제가 무의미해진다.**

4.2 차이점 - 결과를 가른 것은 ‘탐지 - 대응 속도’

근본 원인은 같았지만 결과는 갈렸다. Taiko는 외부 모니터링으로 수 시간 내 동결해 피해를 \$1.7M 수준에서 멈췄다. 직접적으로 돈이 달린 일인지라 한번 털리고 서버를 내렸다. 티빙은 자

체 탐지에 실패해 21시간 동안 1,900만 건 규모의 추출을 허용했다. **재난 대응 계획(IR Plan)의 실효성과 탐지 텔레메트리의 차이가 피해 규모를 결정했다.**

거액의 코인 자산이 유출되는 상황에서 모른다면 그건 메인넷을 운영해서는 안된다. 이 사고의 시사점은 github에 올라간 모든 Web3 프로젝트가 소스 관리 레벨에서 프리커밋을 운영하는 것을 제대로 보지 못했고, 대소동이할 것이라는 것이다.

5. 왜 '프리커밋(Pre-commit) 단계'가 핵심인가?

핵심은 단순하다. 시크릿은 커밋된 뒤에 지워도 사라지지 않는다.

- GitHub 에는 모든 커밋 이력이 남는다. 현재 코드에서 키를 삭제해도 과거 커밋 히스토리에 그대로 잔존한다. 따라서 노출된 키는 '삭제'가 아니라 반드시 폐기 후 신규 키로 교체(rotation)해야 한다. (티빙 신고서에 'AWS 키 폐기 + 자격증명 교체'가 함께 적힌 이유다.)
- 공개 저장소는 전 세계에서 검색 가능하며, 자격증명을 자동 스캔하는 봇이 상시 가동된다. 노출된 키의 악용까지 걸리는 시간은 분 단위인 경우가 많다.
- 따라서 방어의 무게중심은 '노출된 뒤 대응'이 아니라 '커밋되기 전 차단', 즉 프리커밋 단계로 이동해야 한다.

이 관점에서 두 사건은 모두 '커밋 직전에 한 번만 걸러졌으면 발생하지 않았을 사고'다.

기본적인 프리커밋 보안 솔루션은 오픈 소스로 차고 넘친다.

6. 권고사항 (Defensive Recommendations)

6.1 프리커밋(노출 방지) — 1 차 보안

1. **Pre-commit 훅 도입:** gitleaks, git-secrets, truffleHog, detect-secrets 등을 커밋 훅으로 강제해 시크릿이 포함된 커밋 자체를 차단.
2. **저장소 측 시크릿 스캐닝:** GitHub Push Protection / Secret Scanning, CI 파이프라인 내 스캔을 의무화(개발자 PC 우회 방지).
3. **.gitignore 정비:** *.pem, *.key, .env, 자격증명 파일 패턴을 기본 차단. 단, .gitignore 는 보조수단일 뿐 스캐닝을 대체하지 못함.

6.2 시크릿 보관 구조 - 근본 개선

4. **하드코딩 전면 금지:** 키·자격증명을 코드에 두지 않고 AWS Secrets Manager / HashiCorp Vault / KMS 에서 런타임 주입.
5. **하드웨어 키 불출(不出) 원칙:** SGX 등 TEE 서명키가 엔클레이브 밖으로 추출되는 경로(빌드 산출물, 테스트 픽스처, 백업)를 설계 차원에서 제거.
6. **단기 자격증명·최소 권한:** 장기 액세스 키 대신 STS/단기 토큰, IAM 최소 권한, 키별 사용 범위 분리.

6.3 사후 통제·탐지 — 피해 최소화

7. **자동 키 로테이션 + 즉시 폐기 절차:** 노출 의심 시 '삭제'가 아닌 '폐기+교체'를 표준 플레이북에 명시.
8. **이상행위 탐지(텔레메트리):** DB 대량 조회·온체인 비정상 출금에 대한 실시간 알림.
9. **사고 대응 계획(IR Plan) 상시화:** 동결·공지·거래소 협조·신고까지의 절차를 사전 정의하고 훈련.
10. **과거 히스토리 정화:** 이미 노출된 키는 git history 재작성(BFG, filter-repo)으로 제거하되, 반드시 키 교체를 선행해야 한다.

7. 맺으며 – LLM 이 있더라도 안일함은 어쩔 수 없다.

Taiko와 티빙은 표면적으로 무관해 보이지만, 보안 관점에서는 **동일한 교과서적 실패의 두 사례**다. 첨단 영지식 증명도, 국가 공인 인증 체계도, 결국 **'개발자가 커밋한 키 하나'** 앞에서 무너졌다.

정교한 공격을 막는 것보다, 스스로 문을 열어주지 않는 것이 먼저다.

해커가 가장 먼저 뚫히는 곳은 공개된 코드 속 키다. 따라서 보안 투자의 우선순위는 화려한 방어 솔루션 이전에

(1) 프리커밋 단계의 시크릿 차단

(2) 전용 시크릿 저장소로의 구조 전환

(3) 정기적인 보안 모니터링

(4) 노출 시 즉시 폐기·교체 플레이북 세 가지에 두어야 한다.

두 사건이 같은 달에 동시에 보여준 교훈은 인간은 늘 실수하고 최악의 상황을 가정하여 시스템을 구성하고 운영해야 한다는 것이다.

부록 — 동일 발코딩 선례

- **Uber (2016):** 비공개 GitHub 저장소에서 확보한 로그인 정보로 AWS 내 이용자 DB 접근, 약 5,700 만 명 정보 노출.
- **Toyota T-Connect (2017–2022):** 협력사가 소스코드를 공개 저장소에 올리며 DB 접근키 하드코딩, 약 5 년간 노출(29 만여 명 영향 가능).
- **데이원컴퍼니(패스트캠퍼스, 2026):** GitHub 마스터 계정 키값 탈취를 통한 침입 — 티빙과 동시기 발생한 동일 계열 사고.

출처

- CoinDesk, "Taiko halts its Ethereum layer-2 network after a bridge exploit" (2026-06-22)

- The Defiant, "Taiko Bridge Drained \$1.7M After SGX Signing Key Left Exposed on GitHub"
- Decrypt, "Ethereum Layer-2 Taiko Warns Users to Withdraw Bridge Funds After Security Breach"
- thirdweb / Crypto Times / Quill Audits — Taiko 기술 분석
- 뉴스 1, "해커 표적 된 '깃허브 키'...정보유출보다 DB 접근 공격 '심각'" (2026-06-12)
- 이데일리, "티빙 해킹, 단순 정보유출 넘어 클라우드 계정 관리 논란으로 확산"
- 보안뉴스 'TVING 개인정보 유출 사건'

본 리포트는 공개된 1차 보도 및 보안업체 분석을 종합한 것으로, 일부 기술 세부(자산 구성 등)는 Taiko의 공식 사후 보고서 발표 시 보정될 수 있다.